

Appendix A Scenario Brief

A.1 Purpose

This study uses a realistic example of a small UK online retailer. A single, concrete example allows for a deeper and more focused analysis. Northpay is a standard online e-commerce shop, not a financial institution. NorthPay processes card payments; hence, they are subject to Payment Card Industry Data Security Standard (PCI DSS) security requirements.

The following scenarios provide details of a realistic example organisation across three areas: Technical, administrative, and legal, to accurately measure how well different AI models handle these specific controls.

A.2 Organisation profile

Attribute	Detail
Name (fictitious)	NorthPay Ltd
Sector	Online consumer retail, United Kingdom. A merchant within the payment card industry, and an online retailer rather than a regulated financial institution
Trading history	Incorporated in 2022; four of trading; privately held; registered office in Leeds
Business model	Primary business is sells its own homeware and small electrical goods directly to consumers through their website; currently there is no marketplace sellers, no business-to-business channel and no telephone ordering
Payment acceptance	At the time of sales, the card details are entered into fields supplied by a third-party payment service provider (PSP). The payment form is embedded in a checkout page that NorthPay itself serves. Script on that page initialises the PSP's fields and directs the customer's account data to the PSP. Once the payment has been authorised PSP returns an authorisation result and a token. A full primary account number (PAN) never reaches a NorthPay system.
Annual volume	Approximately 340,000 card-not-present transactions in the last full trading year
Validation route	Merchant Level 3, assigned by the acquirer; validated through Self-Assessment Questionnaire A-EP with quarterly scans by an Approved Scanning Vendor (ASV)
Assessment history	An Attestation of Compliance was signed at each of the last two annual validations. This is the second cycle assessed against PCI DSS v4.0.1

Attribute	Detail
Cardholder data environment (CDE)	NorthPay does not store customer credit card numbers, also known as Primary Account Numbers (PAN), on its own systems. However, the online storefront, checkout page, order management system, and administrator access paths are included in the security review (or deemed in scope of PCI assessment) because they connect to or impact the secure Cardholder Data Environment (CDE). NorthPay should follow security requirements stated in the PCI-DSS standard for these systems to prevent data from being intercepted or compromised.
Headcount	61 staff on the payroll
Security function	Two people: an Information Security Manager reporting to the Chief Technology Officer, and a compliance analyst working three days a week. No in-house Qualified Security Assessor (QSA)

Table A.1: The NorthPay organisation profile.

A.3 Technical environment

Hosting and network

All production workload runs in Amazon Web Services, in the London region and spread across three availability zones. NorthPay does not have its own data centre and no on-premises server estate except the office, which consists of networking, printers and a network-attached storage device used by the marketing team.

The storefront/website is built using Node.js, an application behind a content delivery network and a web application firewall. Order management, stock control and returns run on a commercial software-as-a-service platform reached over the public internet. Encrypted database snapshots and log archives replicate nightly to the Dublin region for recovery.

Production and non-production accounts are separated within a single cloud organisation. Admin access to AWS production environment is over a separate internal administration network (separate vLAN) rather than directly from the general office network.

The production estate is segmented using a single virtual private cloud (VPC) with public and private subnets in each availability zone. The application tier and the

database sit in private subnets, and only the load balancer sits in a public subnet. Traffic filtering between each tiers via stateful security groups on each instance.

The settlement file is collected by a scheduled job over SFTP, authenticated with an SSH key pair held on a finance workstation. A second scheduled job retrieves stock availability files from a logistics partner over FTP in passive mode, inside the partner's own tunnel.

Cloud hosts synchronise to the platform time service. The software-as-a-service platforms keep their own clocks, and their exports are timestamped in UTC by the order management platform and in local time by the helpdesk platform.

Identity and access

A single cloud identity provider federates single sign-on to the cloud console, the order management platform, the PSP merchant portal, the helpdesk platform and the collaboration suite. The same provider provides multi-factor authentication (MFA) and conditional access on any of those applications.

Access is granted through groups rather than to individuals, and fourteen groups are in use; three of them were created for a project which finished in 2025 and still carry members.

At present multi-factor authentication is enforced on AWS cloud console and the collaboration suite.

Roughly 40 of the 61 staff hold an account in at least one system that is connected to, or impacts, the CDE: 18 in engineering, 14 in customer support, 6 in finance operations, and the 2 in security and compliance. Marketing, warehouse and logistics staff hold no such account.

The identity provider enforces a minimum password length of ten characters with complexity, an expiry of ninety days and lockout after six failed attempts. Administrative console sessions time out after sixty minutes of inactivity and sessions on the order management platform do not time out while the browser tab remains open.

No automatic account de-provisioning in place. Removal of access from the software-as-a-service platforms is done by hand on each platform.

Data flows and storage

Customer support staff resolve disputes through the PSP merchant portal. PSP only display first six and last four digits of the PAN alongside the authorisation code.

Finance team reconcile a daily settlement file from the PSP. The daily settlement file lists the transaction token, the last four digits and the settlement amount.

The order management platform stores the customer's name, delivery and billing address, contact details, order history and the last four digits of the card. Such data is considered as Personal Identifiable Information (PII) is in scope of GDPR. All the databases are encrypted with AES-256.

No full PAN, sensitive authentication data and no card verification value (also known as CVV code that can be found on the back of the payment card) is stored or transmitted anywhere in the estate.

Public traffic is secured using TLS 1.2 and TLS 1.3, using a certificate from a public certificate authority which renews automatically. All earlier protocol versions are disabled.

No inventory of cryptographic algorithms, protocol versions, certificates, key locations and key holders is maintained. Certificate expiry dates are tracked in a spreadsheet kept by one engineer.

Logging and monitoring

All AWS logs from Cloud audit trail events, network flow logs, load balancer logs and application logs are ingested in to a cloud-native security information and event management (SIEM) platform.

According to the current licence, the SIEM retains 90 days of searchable logs.

Older logs are deleted after 90 days or automatically overwritten as needed. As it stands, no offline or separate logs archive has been configured.

The order management platform produces its own administrator activity log, visible in that platform's interface and not forwarded to the SIEM. A set of random alerts is set up, and alerts arrive in a shared mailbox watched between 08:00 and 18:00 on working days. However, there is no twenty-four hour security operations centre.

Endpoints and change

Staff use company-issued laptops are with Windows 11 operating systems and are managed through a centralised device management tool. All the laptops are configured with full-disk encryption and automatic patching enabled.

Personal devices are also allowed and currently used for email and calendar but are not permitted to reach systems connected to the CDE. This restriction is currently enforced by convention rather than by conditional access policy.

All the software development codes are stored in a AWS based private code repository, a pull request requires one approving review, and a continuous deployment pipeline releases to production several times a week. Deployment credentials are held as repository secrets.

Quarterly ASV scans and one annual external penetration test are commissioned. The last penetration test was carried out in February 2026, and three medium-severity findings from it remain open.

A.4 Administrative environment

Governance

No information security steering group exists. Security matters reach the monthly senior leadership meeting when the Information Security Manager puts them on the agenda. In practice the Chief Technology Officer owns the PCI DSS programme, although this has not been written down anywhere.

Policy/ISMS estate

A set of template policies was purchased three years ago and lightly edited. Several name job titles that no longer exist. The last recorded review was in February 2025, and no approval signature, owner or review cycle is recorded on any of them.

Roles and training

Job descriptions for engineering and customer support make no mention of security responsibilities.

There is no written matrix separating the controls the PSP operates from those NorthPay retains.

An annual all-staff security awareness module is delivered through the learning platform. The training completion rate is at 78% in the last year. Staff who handle disputes or hold administrative access receive no role-specific training.

Third party suppliers

Eleven suppliers touch the cloud environment in some way. Currently there is no single register of suppliers maintained, and no due diligence is carried out at the time the contract is signed or annually.

Incident handling

Currently no IT incident procedure or related activities. No security-specific incident response plan has been written, hence no roles have been assigned for a suspected compromise of card data, and the notification path to the acquirer has never been tested.

Risk and evidence

NorthPay has produced no documented risk analysis of the kind v4.x expects where the frequency of a control is left to the entity to determine. Evidence for the last validation was assembled in the fortnight before the deadline, largely from screenshots and email threads.

A.5 Legislative and regulatory environment

NorthPay is a controller of customer personal data under the UK GDPR and the Data Protection Act 2018 [3], and is registered with the Information Commissioner's Office.

It relies on performance of a contract for order fulfilment, on legitimate interests for fraud prevention, and on consent for marketing.

No Data Protection Officer has been appointed and the responsibility sits informally with the Head of Finance and Legal, who holds no data protection qualification.

The personal data held comprises name, delivery and billing address, email address, telephone number, order history, the last four digits of the card, IP address and support correspondence. No special category data is processed. Order records are kept for seven years to meet tax record-keeping requirements.

No retention period has been set for support tickets, marketing lists or log data, each of which contains personal data.

Head of Finance and Legal acknowledged that, under the UK GDPR, a controller must notify the Information Commissioner within seventy-two hours of becoming aware of a personal data breach where the statutory criteria are met [3]. However, NorthPay holds no internal procedure that would meet that clock, and the relationship between that duty and the notification it owes its acquirer following a suspected card compromise has never been mapped.

Nightly replication of encrypted backups to the Dublin region constitutes a transfer outside the United Kingdom; the transfer is covered by the UK's adequacy regulations for the European Economic Area, but no record of it has been documented.

Email marketing falls under the Privacy and Electronic Communications Regulations 2003 as well as the UK GDPR [4]. Returns and refunds, which is the route by which most disputes reach customer support, are governed by the Consumer Rights Act 2015 [5] and the Consumer Contracts (Information, Cancellation and Additional Charges) Regulations 2013 [6].

One boundary should be stated without ambiguity. NorthPay does not lend, does not offer credit at the checkout, does not hold client money and holds no permission of any kind from the Financial Conduct Authority. No clause of the policy should assert an FCA obligation.

A.6 Applicable PCI DSS requirements

It is NorthPay's understanding that the PCI DSS v4.0.1 requirements 7, 8, 10 and 12 are applicable to them because NorthPay hosts the checkout page; its website controls how payment details are sent to the payment provider. Even though NorthPay never actually sees or stores the card data, its website affects the safety of the transaction. According to the PCI-DSS scoping documentation, this means NorthPay must complete the more detailed Self-Assessment Questionnaire (SAQ A-EP) instead of the basic SAQ A [2].

NorthPay is considered a merchant, and Merchant levels are decided by credit card companies and banks, not by the official PCI Council [1]. Level 3 is for companies

handling between 20,000 and 1,000,000 online sales a year. With 340,000 transactions, NorthPay fits perfectly into this category.

The following table summarises the applicable PCI DSS Security requirements.

Requirement	Focus	Why it is in scope
Requirement 7	Restricting access to system components and cardholder data by business need to know	Access governance is expressed primarily through policy and role definition
Requirement 8	Identifying users and authenticating access to system components, including multi-factor authentication	Identity and authentication rules are naturally policy-level statements
Requirement 10	Logging and monitoring all access to system components and cardholder data	Log management, review cadence and retention are policy commitments as much as technical settings
Requirement 12	Supporting information security with organisational policies and programmes, including third-party oversight and incident response	This is the governance backbone of the standard and is inherently policy-driven

Table A.2: The four PCI DSS v4.0.1 requirement areas in scope, and why each is in scope.